



ISP-003 — Data Breach and Incident Response Procedure

Overleaf Publishers Ltd · Co. No. 15735226 · VAT No. 479581629 · Version 1.0 · July 2026 · chainsawcourses.com

1. PURPOSE AND SCOPE

This procedure establishes how Overleaf Publishers Ltd detects, contains, investigates, notifies, and recovers from information security incidents and personal data breaches. It applies to all personnel, contractors, and systems. Document reference: ISP-003.

A personal data breach is any security incident that leads to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to personal data. Under UK GDPR, certain breaches must be reported to the Information Commissioner's Office (ICO) within 72 hours of becoming aware, and affected individuals notified without undue delay where the breach is likely to result in high risk to their rights and freedoms.

2. INCIDENT CLASSIFICATION

CATEGORY — DESCRIPTION	EXAMPLES
P1 Critical — active breach; mass data exposure; platform compromise; ransomware	Database exfiltration; admin credential compromise; ransomware on infrastructure
P2 High — confirmed breach; limited exposure; no evidence of misuse yet	Accidental bulk email disclosure; single learner record exposed; lost unencrypted device
P3 Medium — suspected breach or near-miss; potential vulnerability identified	Phishing attempt; unusual login activity; misconfigured access control discovered
P4 Low — minor procedural failure; no confirmed data exposure	Incorrect data sent to single recipient and recovered; temporary system misconfiguration corrected

3. INCIDENT RESPONSE PHASES

PHASE	ACTIONS
1 — Detect and Report	Any suspected incident reported to Director immediately on discovery. Incident logged in Security Incident Register with date/time, discoverer, and initial description.
2 — Triage (within 1 hour)	Director assesses classification (P1–P4). P1/P2: immediate escalation and containment. P3/P4: investigation initiated within 4 hours.
3 — Contain (within 4 hours for P1/P2)	Affected systems isolated or access revoked. Compromised credentials changed. Evidence preserved. Platform availability maintained where safely possible under the BCP.

4 — Assess	Scope of breach established: data types affected; number of individuals; likely consequences; whether breach is ongoing or contained.
5 — ICO Notification (within 72 hours)	For breaches likely to result in risk to individuals' rights and freedoms, notification submitted to ICO via ico.org.uk/report-a-breach within 72 hours of awareness.
6 — Individual Notification	Where the breach is likely to result in high risk to individuals, affected learners notified without undue delay via email, with clear description of the breach, its likely consequences, and mitigating steps taken.
7 — Investigate	Full root cause analysis conducted. Contributing factors identified. Interim corrective actions documented.
8 — Recover	Systems restored; data integrity verified; enhanced monitoring implemented. Recovery actions documented.
9 — Review and Improve	Post-incident review completed within 30 days. NC raised in Nonconformance Register. Preventive actions implemented to prevent recurrence.

4. ICO NOTIFICATION REQUIREMENTS

Notification to the ICO is required when a personal data breach is likely to result in risk to the rights and freedoms of natural persons. Notification must include:

- Description of the nature of the breach, including categories and approximate numbers of individuals and records concerned.
- Name and contact details of the Data Protection contact (Director: info@chainsawcourses.com).
- Description of the likely consequences of the breach.
- Description of measures taken or proposed to address the breach, including measures to mitigate its possible adverse effects.

Where full information is not available within 72 hours, initial notification is submitted with the information available, with further information provided as it becomes available (phased notification).

5. BREACH REGISTER

All incidents are logged in the Security Incident and Breach Register, regardless of whether ICO notification is required. The register contains: incident reference; date/time detected; date/time reported; classification; description; personal data categories and volumes affected; containment and recovery actions; ICO notification reference (if applicable); individual notification status; and closure date. The register is reviewed at each management review and retained for a minimum of 7 years.

6. DRILL AND TESTING

The incident response procedure is reviewed annually and tested at least every 2 years via a tabletop exercise. Test outcomes are documented and any gaps in the procedure are raised as improvement actions.

